

【漏洞公告】PostgreSQL 弱口令漏洞

笔记本：安全预警

创建时间：2018/11/2 21:32

更新时间：2018/11/2 21:32

作者：苏醒

URL：https://help.aliyun.com/knowledge_detail/37544.html?spm=a2c4g.11186631.2.10.bfa36418SOQPTD

PostgreSQL 是一个功能强大的开源对象关系数据库系统。本文针对 PostgreSQL 在使用过程中可能出现的弱口令漏洞，提供一系列修复方案，供您参考使用。

修复方案

禁止 PostgreSQL 以 root 权限运行，建议使用独立账号运行。

1. `adduser dbusersudo su - dbuser`

修改数据库账号为强密码。例如，

1. `alter user postgres with password 'aliyunSecurity1234_';`

使用密码认证。检查 PostgreSQL 配置文件 `pg_hba.conf` 中是否存在 `host all all 0.0.0.0/0 trust`，建议修改为使用密码认证。

查看是否存在恶意 UDF 函数。

1. `select proname,prosrc from pg_proc where proname = 'exec111';`

查看是否存在可疑 UDF 函数。

1. `select proname,prosrc from pg_proc;` // 查看哪些函数不是系统预设的、或者管理员自己添加的

查看是否存在可疑存储过程。

1. `select tgrelid from pg_trigger;`

检查自己服务器是否存在 `/tmp/testproxy.so` 文件。